Research.gov - Proposal Status Panel Summary

research.gov/gapps-web/gapps/viewApplicationPanelSummary

Agency Name:

National Science Foundation

Agency Tracking Number:

2533187

Panel Summary

Proposal summary:

This proposal aims to enhance the security of the Scientific Python Open Source Ecosystem (SP-OSE), by specifically addressing supply chain, access, and insider attacks, based on the integration of contributor reputation, automated anomaly detection, and previously developed community-driven security coordinations (SPECs).

Intellectual Merit:

STRENGTHS:

+ Scientific Python Open Source Ecosystem is widely used for scientific research, for example by universities and national labs. Improving its security leads to a big impact of securing scientific research that is based on Python.

+ The proposed work, especially the three types of vulnerabilities (i.e., supply chain, access, and insider attacks) to be addressed, is clearly described.

+ PIs are tightly related to SP-OSE. They developed SP-OSE foundational projects and SPECs and have a clear understanding of the vulnerabilities (e.g., supply chain attacks), which paves the way for continuously improving the security of SP-OSE.

WEAKNESSES:

- The proposed technical solutions are quite generic. They lack detailed descriptions of the technical approaches and methodologies to mitigate vulnerabilities. Additionally, important details such as the source of the data, its intended use, and the team’s plan for user feedback are missing.

- Evaluation and validation plan, especially quantitative assessment of the proposed security approaches, project milestones, and timeline, are missing.

- The team needs a member who has a background and expertise in security to provide detailed vulnerability mitigation implementations (e.g., related to reputation system and anomaly detection) and to augment the feasibility of the proposed work.

Broader Impacts:

STRENGTHS:

+ The proposed community-driven security tools and standards to mitigate vulnerabilities, if successful, can be replicable to other Python-related ecosystems.

WEAKNESSES:

- There are no concrete evaluation metrics (e.g., vulnerability reduction rate, attack detection success rate).

- Dissemination plan of the developed vulnerability mitigation plan, including broadening the community of this ecosystem to more scientific research groups and soliciting feedback from end-users, is unclear.

Safe-OSE specific review criteria:

STRENGTHS:

+ The proposed work of improving the security of SP-OSE that is currently used across a wide range of scientific research domains, from high-energy physics to national defense, aligns well with current national concerns about software supply chain security and open-source reliability. The inclusion of current case studies, such as LHC, Belle, and ATLAS, strengthens this argument.

WEAKNESSES:

- While the proposal classifies vulnerabilities into supply chain, access control, and insider threats, the threat modeling could benefit from more in-depth technical discussions, especially regarding how tools like anomaly detection and reputation systems will be practically integrated and tested.

-While the proposal references community endorsement, it does not explicitly include third-party letters of collaboration or endorsement for major institutional stakeholders (e.g., DOE, NASA, and NSF-funded facilities).

Panel Conclusion:

The proposal addresses a significant security problem with a widely used open-source ecosystem. However, it lacks a concrete technical and assessment plan to mitigate the identified vulnerabilities. Given the fact that the current team is mainly experienced in

scientific computing, an additional team member with a security background would enhance the team's ability to design robust threat models, develop and validate secure tooling.

The summary was read by/to the panel and the panel concurred that the summary accurately reflects the panel discussion.

PANEL RECOMMENDATION: Low Competitive